

Documentation-Driven Threat Analysis

Research Work Plan

After documentation-layer closure – Revision 2

From the frozen documentation metamodel to Base Analysis, BAE and multi-method
analysis

Baseline. `ec6c0107e0d5c0460d2afcb12dae6f40bc5e6c5`.

Status. Current execution plan after the Chapters 2–4 documentation-layer freeze. W0 is CLOSED and BA0 is NEXT. It supersedes Revision 1 sequencing but does not reopen closed documentation semantics.

15 August 2026

Contents

1	Current checkpoint	2
2	Thesis-writing freeze gate: Chapters 2–4	2
2.1	W0.1 – Chapter 2 – CLOSED	2
2.2	W0.2 – Chapter 3 – CLOSED	2
2.3	W0.3 – Chapter 4 – CLOSED	2
3	Reopen policy for frozen chapters	3
3.1	Chapter 2	3
3.2	Chapter 3	3
3.3	Chapter 4	3
4	Base Analysis block	3
4.1	BA0 – Base Analysis responsibility and boundary	3
4.2	BA1 – Minimal BAE ontology	3
4.3	BA2 – Relations and canonical action vocabulary	4
4.4	BA3 – Document-to-BAE derivation, provenance and authority	4
4.5	BA4 – Multi-level views and projections	4
4.6	BA5 – Controlled vocabulary and authoring assistance	5
4.7	BA6 – Base Analysis closure and regression	5
5	Generic analysis envelope	5
5.1	A1 – AnalysisRecord	5
5.2	A2 – Finding	5
5.3	A3 – Change/provenance integration	5
6	Method-neutral overlay and concrete evaluations	5
6.1	O1 – Generic overlay contract	6
6.2	O2 – STRIDE	6
6.3	O3 – Closed-loop design improvement	6
6.4	O4 – STRIDE-AI	6
7	Later neutrality challenges and ThreatForge	6
8	Next authorized microstep	6

1 Current checkpoint

The governed documentation metamodel is closed for the current thesis scope through:

```
Project problem framing [method precondition]
  -> MacroRequirement
  -> Decision
  -> FunctionalRequirement
  -> SpecializedRequirement [abstract]
    -> SecurityRequirement
```

The common requirement abstraction is also closed:

```
GovernedDocument
|
|-- Requirement [abstract]
|   normativeClause : NormativeClause [1..*]
|   |
|   +-- FunctionalRequirement
|   |-- SpecializedRequirement [abstract]
|       |-- SecurityRequirement
```

Requirement is the governed normative obligation. The separate L1 **NormativeObligation** wrapper is rejected. **SecurityRequirement** adds **protectedSecurityProperty : SecurityProperty [1]**; its security failure mode must be identifiable in inherited normative clauses and its identity is cause-neutral.

2 Thesis-writing freeze gate: Chapters 2–4

2.1 W0.1 – Chapter 2 – CLOSED

Chapter 2 is semantically closed. Only typographical/citation correction, stale forward-reference cleanup and terminology normalization that does not change claims are allowed.

2.2 W0.2 – Chapter 3 – CLOSED

Chapter 3 is semantically closed. G1–G4 and the thesis research scope remain unchanged; finalization is editorial only.

2.3 W0.3 – Chapter 4 – CLOSED

The finalization commit consolidates the already closed results reached after S1R1: Requirement abstraction, normative clauses, rejection of NormativeObligation, S2 SecurityRequirement, protected property, failure-mode explicitness, cause neutrality, single governing security property, and negative boundaries.

W0 exit gate

W0 is CLOSED: Chapters 2, 3 and 4 are CLOSED / FINAL for the current thesis scope and are not routinely edited during Base Analysis, Finding, overlay or STRIDE work. The next authorized microstep is BA0.

3 Reopen policy for frozen chapters

3.1 Chapter 2

Reopen only for a material literature/factual error, a materially unsupported claim, or falsification of a foundational distinction used by the thesis.

3.2 Chapter 3

Reopen only if the research gap or evaluated thesis scope is materially falsified/changed, or prior work is found to solve a claimed discontinuity in the evaluated end-to-end sense.

3.3 Chapter 4

Reopen only for a concrete recurring downstream counterexample that cannot be represented without changing the governed documentation contract. A new BAE relation, plugin-private taxonomy field, vocabulary suggestion or implementation control is not by itself a reopen trigger.

Reopen discipline

Every reopening must name the counterexample, modify the minimum owning layer and regress the previously accepted corpora.

4 Base Analysis block

4.1 BA0 – Base Analysis responsibility and boundary

Define Base Analysis as a governed, methodology-neutral analyzable representation of system/project knowledge grounded in governed documentation and explicit reviewed additions. Falsify these boundaries:

- not a second narrative documentation hierarchy;
- not a STRIDE DFD by definition;
- not automatically canonized NLP/LLM extraction;
- may integrate reviewed structure derived from several governed documents;
- one canonical knowledge base may support several projections;
- an analysis method consumes the representation but cannot silently redefine its semantic core.

BA0 exit gate

A precise responsibility statement and non-goals are accepted before BAE taxonomy design.

4.2 BA1 – Minimal BAE ontology

Start from the smallest vocabulary forced by the facial-access corpus:

```
BAE [abstract]
+-- Actor
+-- Asset
'-- Interaction
```

Pressure-test whether first-class Component/ServiceCapability, DataStore, CommunicationChannel, InterfaceContract, Boundary, Location/Environment or State/Condition are actually necessary. These are hypotheses, not pre-approved metaclasses.

BA1 exit gate

Minimal generic BAE set with definitions, stable identity rules and negative controls.

4.3 BA2 – Relations and canonical action vocabulary

Define the smallest stable relation vocabulary needed for a graph without uncontrolled synonym growth. Candidate pressure points: source/target participation, produces/consumes/handles, stores/retrieves, dependsOn, boundary relations, invokes/delivers/receives and capability provision/consumption.

```
L1 semantic relation
    !=
L2 canonical lexical label
    !=
L3 authoring suggestion / synonym normalization
```

Avoid a generic **affects**-style escape relation and avoid freezing a universal verb taxonomy prematurely.

4.4 BA3 – Document-to-BAE derivation, provenance and authority

Required distinctions:

```
governed document fact
candidate BAE extraction / suggestion
reviewed canonical BAE
reviewed analytical addition
```

Close stable identity, source references, authoritative/supporting sources, no automatic noun-to-BAE canonization, no automatic synonym merge, explicit candidate acceptance/rejection, BAE-to-document traceability, and explicit reviewed additions.

4.5 BA4 – Multi-level views and projections

Views are projections of one canonical Base Analysis, not competing authored models. Candidate views:

1. Context / actor view.
2. Interaction view.
3. Asset / data-flow view.
4. Boundary / deployment view, only if boundary is canonical BAE semantics.
5. Security overlay view projecting SecurityRequirements/properties without turning Base Analysis into a threat-method model.

A view may omit information for readability but must not imply that omitted information does not exist.

4.6 BA5 – Controlled vocabulary and authoring assistance

Tooling may suggest reuse of Actor/Asset/BAE names, canonical actions/predicates, probable duplicates/paraphrases, taxonomy entries, BAE candidates/relations and existing references. Similarity or an LLM output never silently establishes identity, parentage, ownership or canonical BAE status.

```
LLM-assisted authoring
-> vocabulary / BAE suggestions
-> reviewed governed documentation

LLM-assisted analysis preparation
-> candidate BAE / relation extraction
-> reviewed Base Analysis
```

BA5 exit gate

Assistance reduces synonym/paraphrase drift without making the tool semantic authority.

4.7 BA6 – Base Analysis closure and regression

Regress closed documentation corpora and at least one structurally different holdout. Verify identity stability under paraphrase, mutation handling, view consistency, absence of method-specific threat categories in the core and explicit diagnostics for insufficient documentation.

Base Analysis exit gate

A methodology-neutral Base Analysis can be built and reviewed from governed documentation plus explicit reviewed additions, with stable BAE identities, relations, provenance and projections.

5 Generic analysis envelope

5.1 A1 – AnalysisRecord

Define common identity, method/version, scope, baseline and execution/provenance envelope with method-owned payload remaining plugin-owned.

5.2 A2 – Finding

Define a reviewed common result envelope that can reference affected BAE and governed requirements without copying method taxonomy into the common core.

5.3 A3 – Change/provenance integration

Resolve S1.5 many-to-many analysis/document history and distinguish analysis scope from accepted change. Test whether a general change-event abstraction is actually necessary.

6 Method-neutral overlay and concrete evaluations

6.1 O1 – Generic overlay contract

Define compatibility, scope selection, required BAE/view capabilities, method-owned payload, diagnostics, finding derivation and failure behavior.

6.2 O2 – STRIDE

Use STRIDE only after Base Analysis and O1 are stable enough for falsification.

6.3 O3 – Closed-loop design improvement

```
governed documentation
-> Base Analysis / views
-> analysis overlay
-> AnalysisRecord
-> reviewed Finding
-> accepted governed change / SecurityRequirement
-> Base Analysis refresh
-> re-analysis
```

6.4 O4 – STRIDE-AI

Reuse the same common contracts without copying STRIDE-AI-private asset/failure/taxonomy semantics into the common core.

7 Later neutrality challenges and ThreatForge

Use LINDDUN and optionally another method as neutrality challenges after STRIDE/STRIDE-AI; do not claim universal neutrality from two implementations. ThreatForge remains an implementation/tooling case study and never establishes DDTA semantic authority.

8 Next authorized microstep

Authorized next step

After the W0 finalization commit, execute only **BA0 – Base Analysis responsibility and boundary**, immediately pressure-tested on the facial-access camera corpus. Do not start STRIDE, AnalysisRecord, Finding or broad BAE taxonomy enumeration before BA0 is closed.